

Complete Architecture Plan

A practical Node.js, Express and TypeScript architecture for secure bidder registration, document intelligence, verification, mock platforms, approved provider integrations, cloud storage and officer-led decisions.

REVISED SYSTEM VIEW

HUMAN-IN-THE-LOOP

MOCK TO PRODUCTION

1. System structure

Clear public edge, private app services, private cloud data, business modules, routing and network boundaries.

2. Working process

Registration to decision is shown as a traceable flow, with exception conditions and an officer-controlled outcome.

3. Integration reality

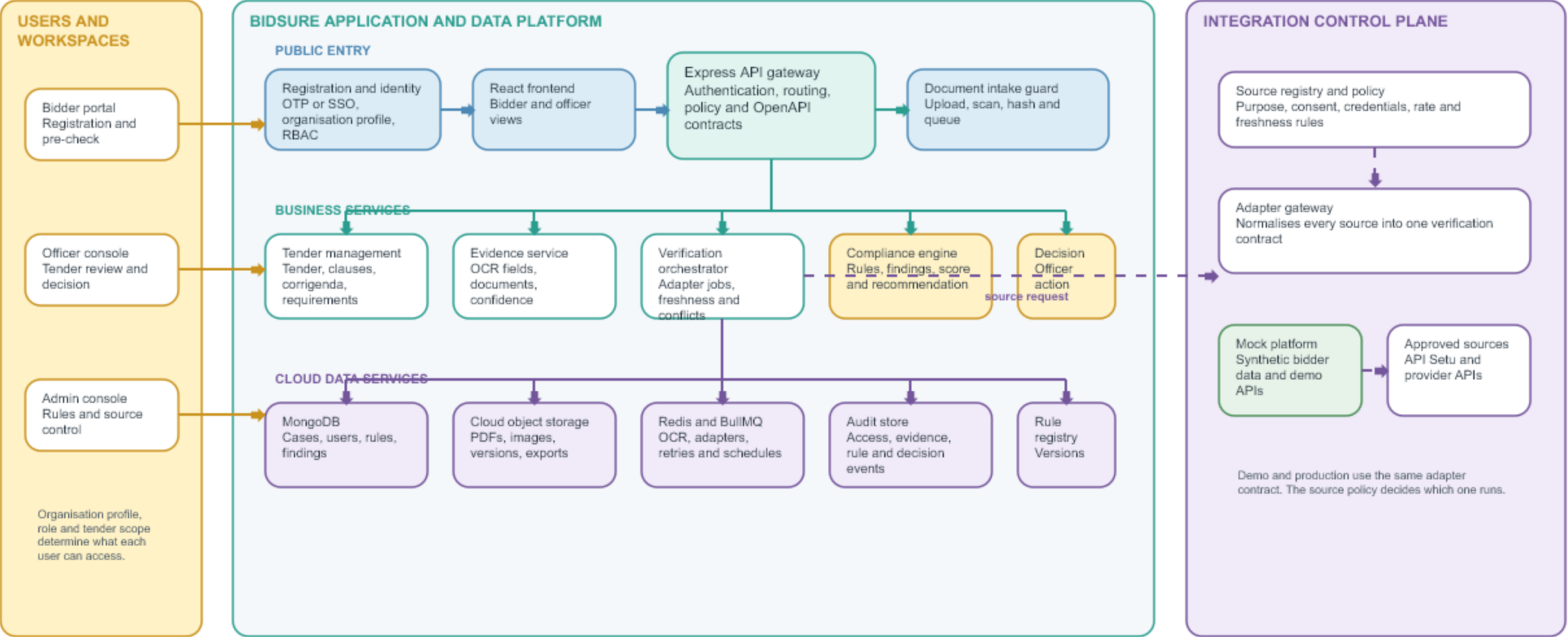
Mock platforms make the SIH demo feasible now. Production sources are accessed only after provider approval, scope and credentials.

Prepared for the BidSure SIH solution review

Architecture revision: complete system design, workflow, AI controls, integration model, cloud storage and operations

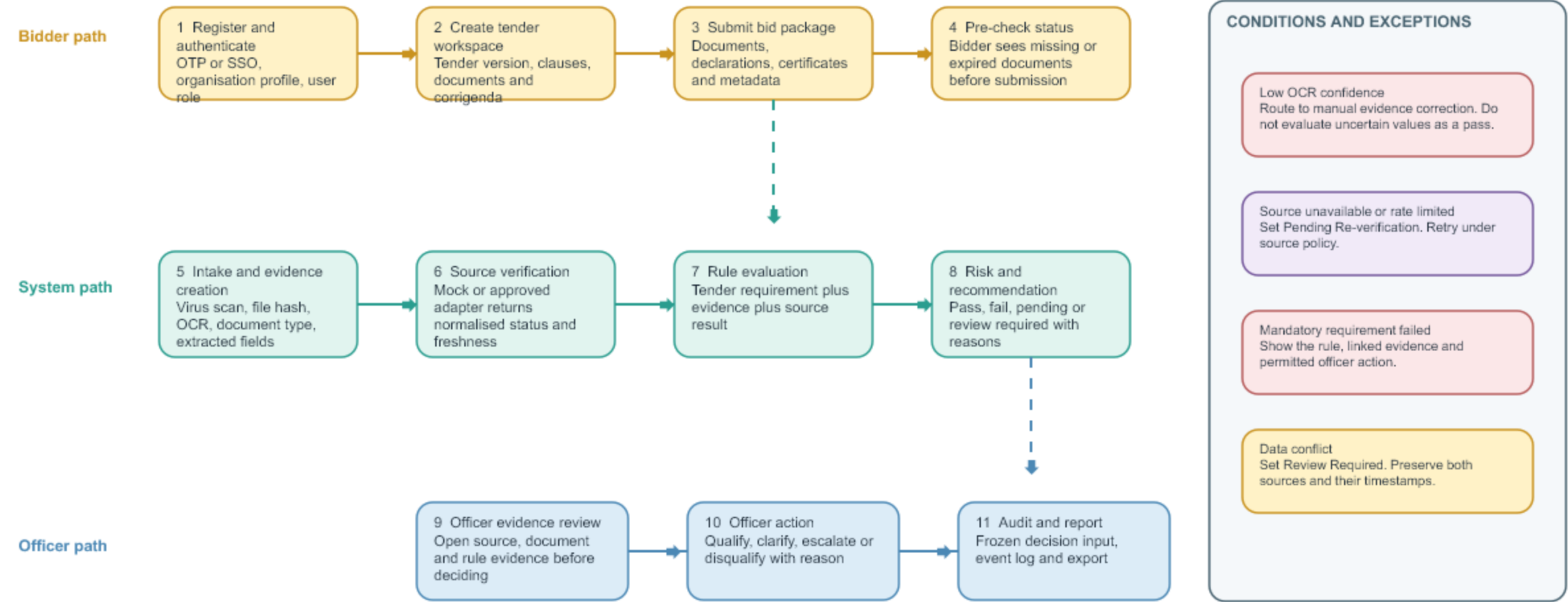
Complete BidSure System Architecture

Registration, authentication, evidence, verification, decision and audit operate as one controlled platform



Bid Processing and Verification Workflow

The platform keeps every stage visible so officers can understand what happened, why it happened and what requires action



AI and Document Intelligence Architecture

AI structures evidence and produces explanations. Rules and officers control the compliance outcome

UNTRUSTED INPUTS

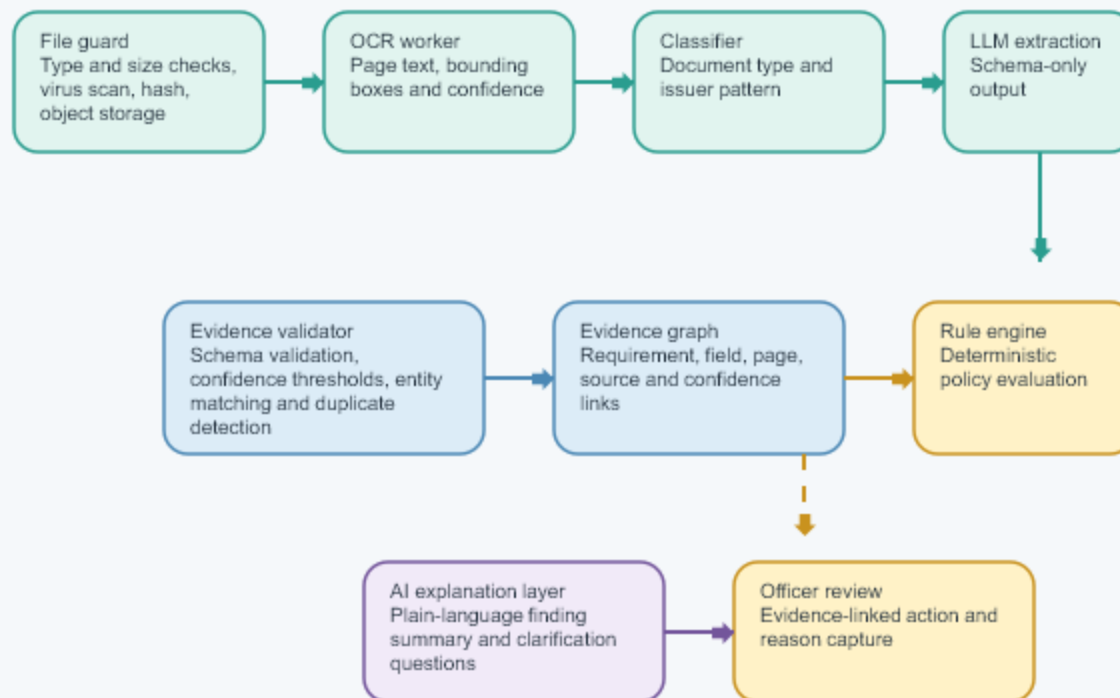
Tender documents
ATC, STC, corrigenda and
requirement clauses

Bidder documents
Certificates, declarations,
authorisations and financial
evidence

Source responses
Mock and provider responses in
source-specific formats

Documents can contain misleading
text. BidSure treats every uploaded
document as data, never as
instructions.

CONTROLLED AI AND EVIDENCE PIPELINE



MODEL SAFETY BOUNDARY

No direct source access
The model cannot call government APIs or use
credentials.

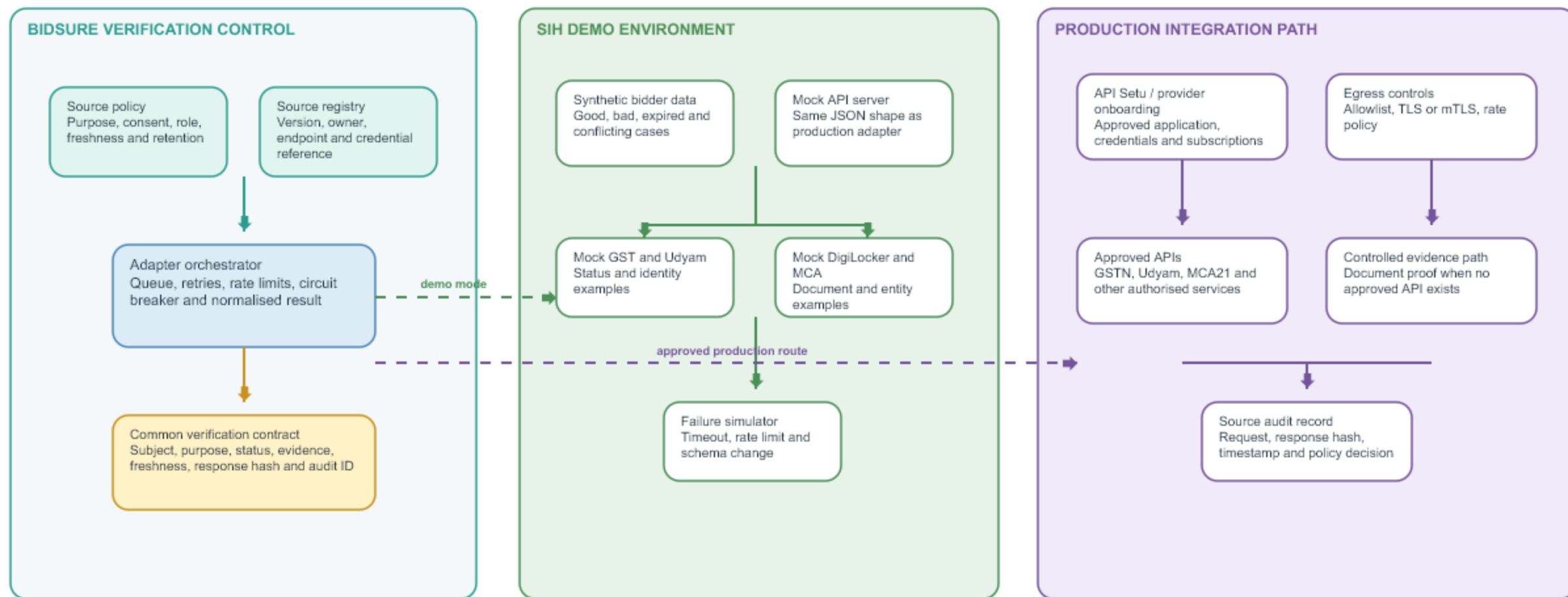
Prompt isolation
Document text remains quoted input; system
policy stays outside the document.

Data minimisation
Redact or use approved local inference before
sending sensitive content to a model.

Reproducibility
Store model/version, prompt template, schema
result and reviewer correction.

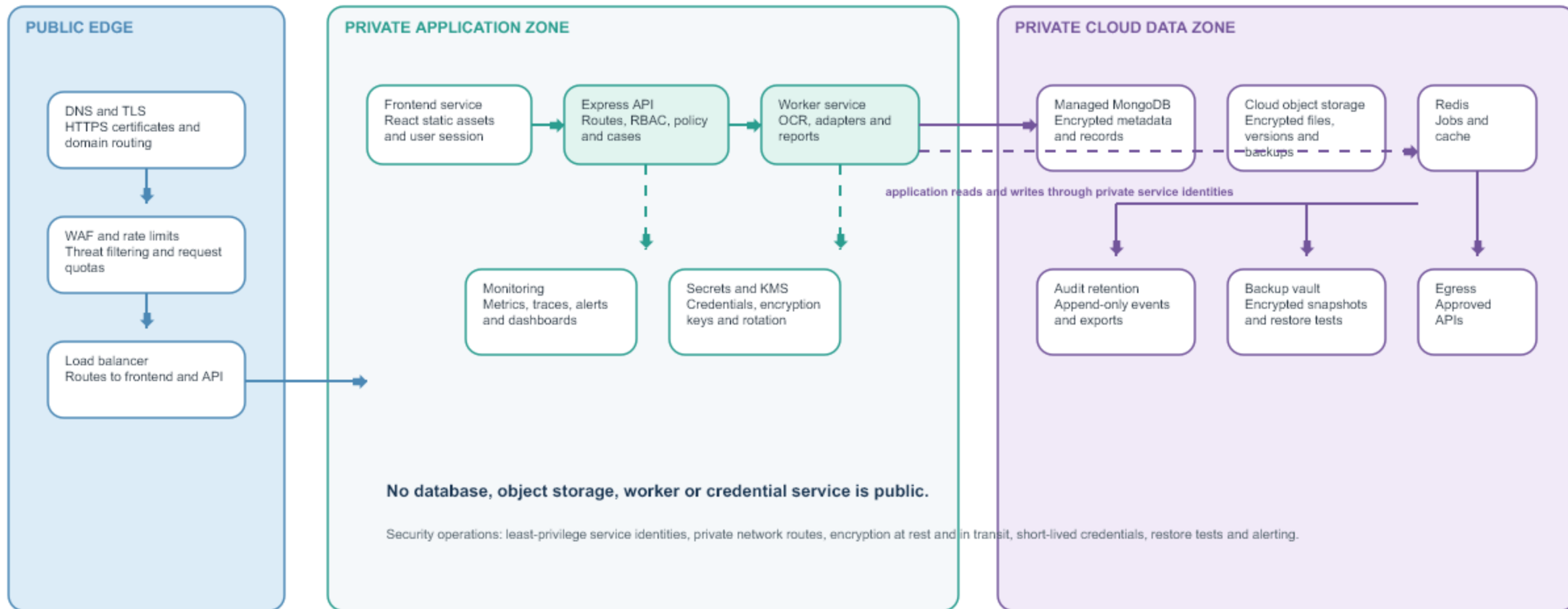
Integration and Mock Platform Architecture

The same adapter contract supports SIH demo data today and approved government data sources later



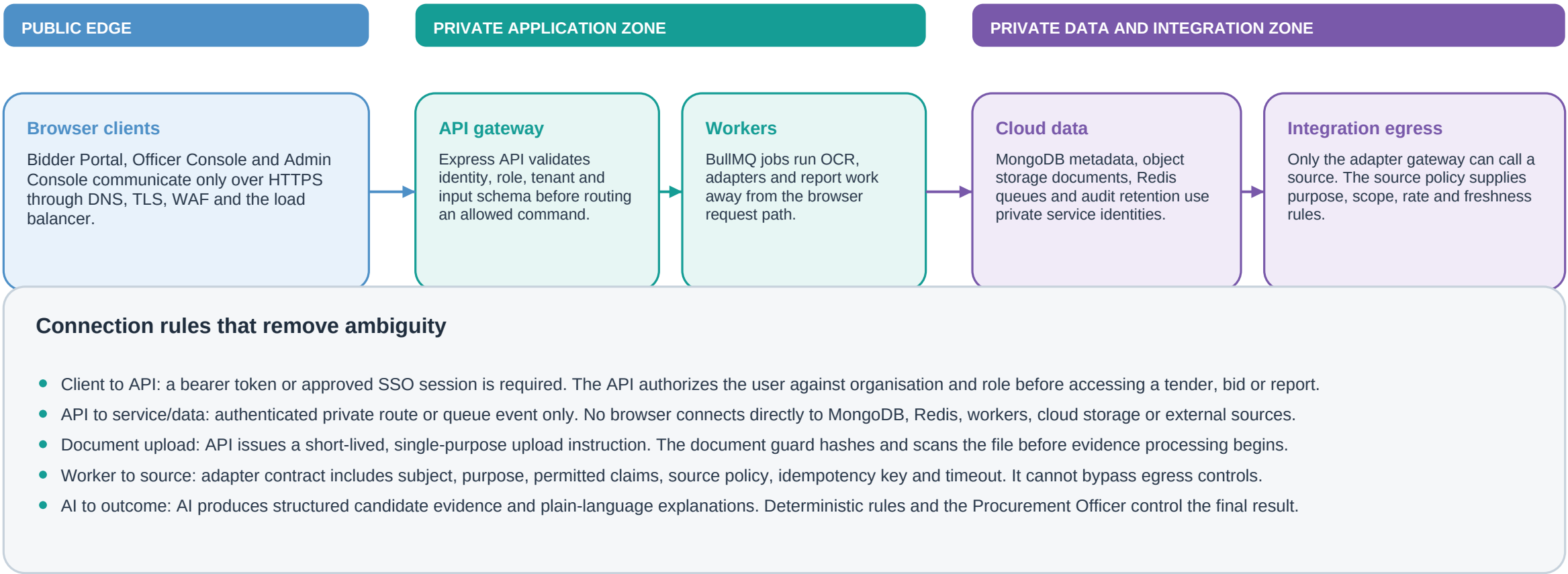
Cloud Storage, Operations and Security Architecture

Cloud storage, worker isolation, secrets, monitoring and recovery support the application without exposing source credentials or evidence



Service Responsibilities and Network Boundaries

This page explains exactly what connects to what, through which route, and under which control.



Routes, Events, Conditions and Decision State

Route names are a proposed API contract: easy to demo, easy to test, and separate from external provider contracts.

Proposed application routes and events

POST /v1/auth/register	Creates user and organisation profile after OTP or SSO proof.
POST /v1/tenders	Creates tender workspace, clauses, criteria and version.
POST /v1/bids/{id}/documents	Creates a guarded upload instruction and records file metadata.
POST /v1/bids/{id}/verification-runs	Queues a verification run after a permitted user action.
worker: verification.requested	Fetches source evidence through the adapter gateway; retries only within policy.
GET /v1/verification-runs/{id}	Returns status, evidence links, score, risk and readable explanation.
POST /v1/decisions	Only an authorised officer can qualify, clarify, escalate or disqualify with a reason.

Low OCR confidence

Do not treat unverified extracted values as pass. Create a manual-evidence task and retain the original file and confidence score.

Source unavailable or rate limited

Return Pending Re-verification. Worker uses bounded retry, exponential backoff and circuit breaker according to source policy.

Conflicting or mandatory-fail evidence

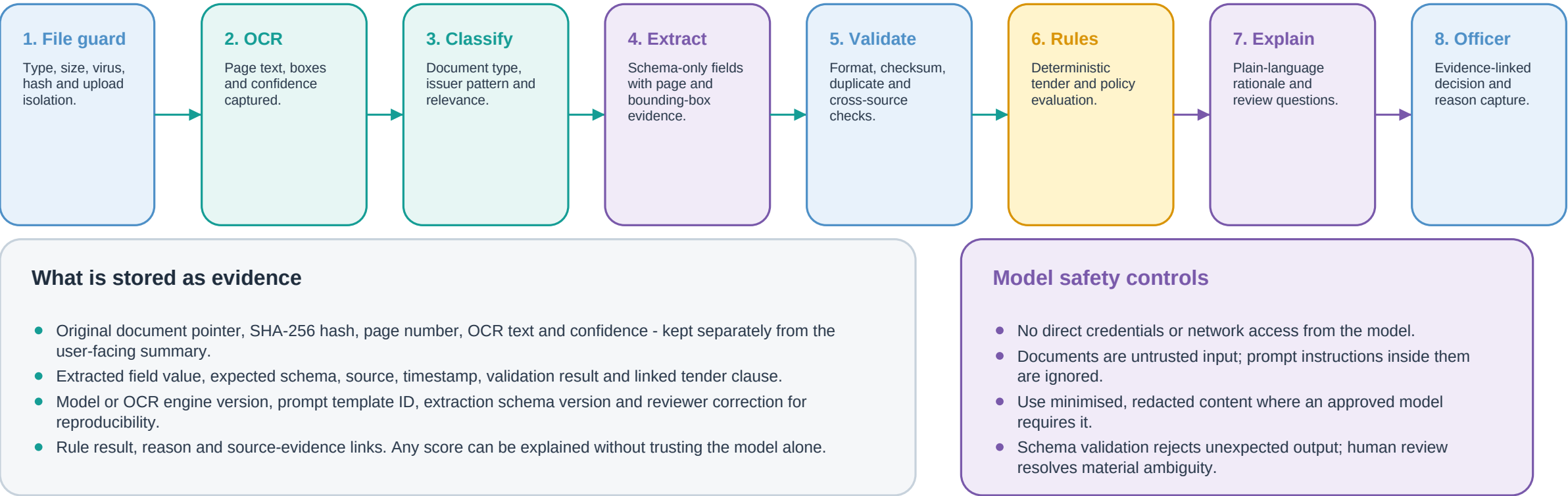
Store both source records and timestamps. Mark the condition and expose it to an officer with linked evidence; never silently overwrite.

Final decision

The score and recommendation are advisory. The Procurement Officer records the action, reason, actor and time in the audit log.

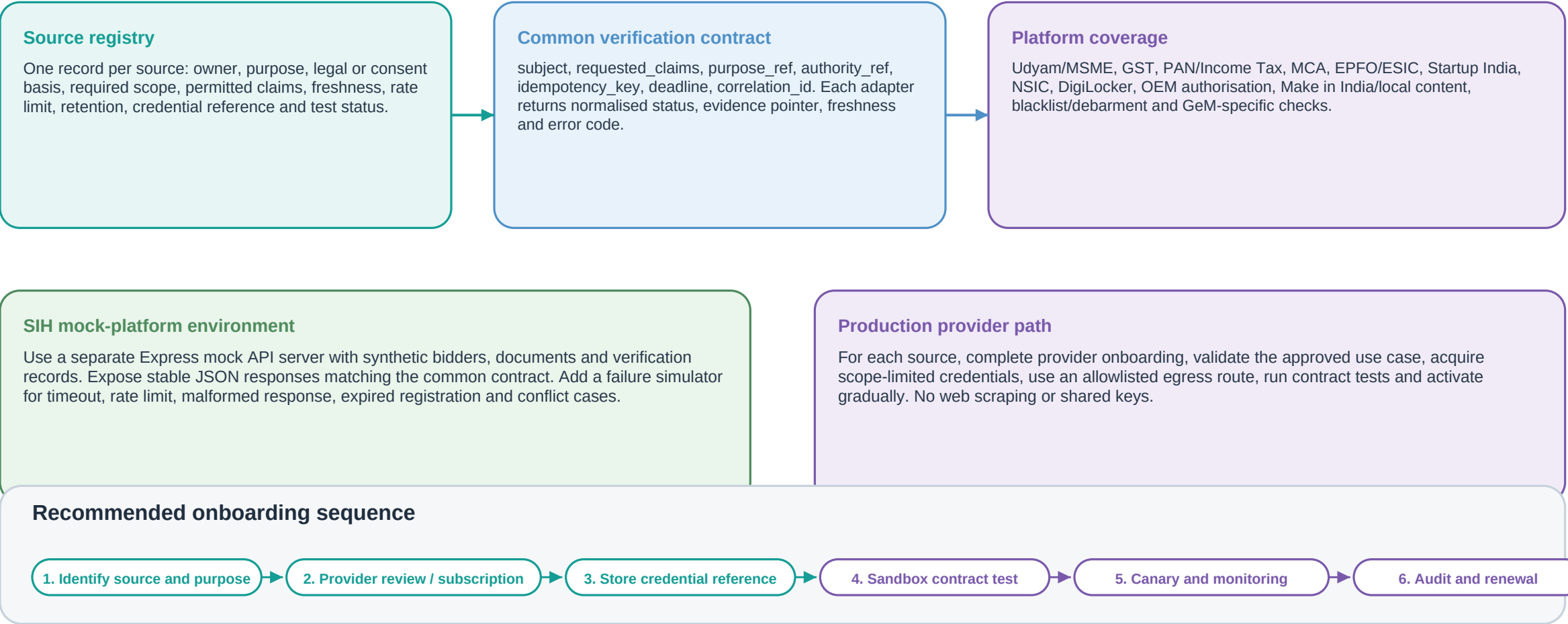
AI and Document Intelligence: A Controlled Evidence Pipeline

The model assists evidence extraction and explanation; it is not a remote super-user and it is not the final decision maker.



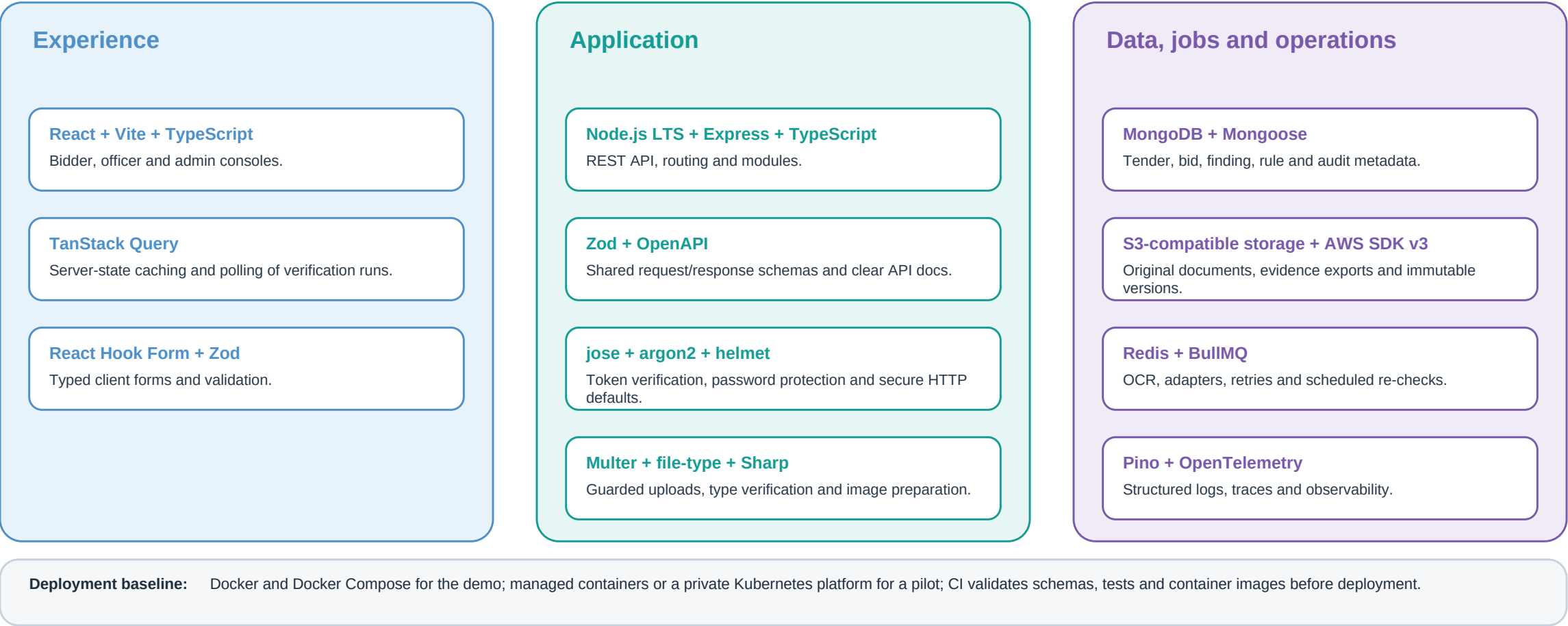
Ten Plus Platforms Without Ten Plus Fragile Implementations

A source registry and common adapter contract make a controlled mock demo possible now and a governed production path possible later.



Recommended Node.js, Express and TypeScript Stack

The SIH build should stay understandable: a modular monolith plus worker process first, with clean interfaces for later scale-out.



Pin package versions in the lockfile and run dependency, licence and security review before connecting to a real provider.

Cloud Storage, Data Protection and Operational Controls

Public access ends at the edge. Evidence, credentials, workers and databases remain in private routes with least-privilege service identities.

1. Upload and evidence

Short-lived upload instruction, file guard, hash, versioned cloud object storage and evidence pointer rather than unrestricted downloads.

2. Access and isolation

Organisation-aware RBAC, ownership checks, privacy-aware fields and private routes. Browser users do not receive database or provider credentials.

3. Secrets and egress

Secret manager / KMS holds source credentials. Adapter egress is allowlisted, scoped, rate limited and monitored.

4. Auditability

Append-only event records contain actor, action, route, policy, source, evidence hash, decision and time. Sensitive values are minimised in logs.

5. Retention and deletion

Rules specify evidence retention, expiry and authorised export. Operational deletion follows review and produces a corresponding audit event.

6. Recovery and resilience

Encrypted backups, restore tests, queue retry policy, circuit breakers and an incident-alert path preserve availability without hiding failure.

Privacy-by-design decisions

- Collect only claims necessary for the tender criterion and preserve the source policy and authority reference alongside every request.
- Keep original files in private cloud object storage. Use short-lived, authorized evidence links for review rather than public URLs.
- Treat provider credentials as non-exportable secrets. Use scoped client credentials or consent-bound flows where the provider requires them.
- Do not send an entire tender packet to a model by default. Redact or minimise sensitive content and preserve a reproducible extraction record.

SIH Demo Scope, Pilot Path and Research Anchors

Build a convincing, auditable demo without pretending that public-source access is automatically available.

Phase 1 - SIH demo

React user flows, Express API, authentication, tender rules, object storage, evidence ledger, BullMQ worker and mock Udyam/GST/DigiLocker/MCA source adapters. Demonstrate normal, low-confidence, timeout and conflict cases.

Phase 2 - integration hardening

Formal source inventory, provider onboarding, security review, contract tests, scoped secret references, egress allowlist, monitoring and review of retention rules.

Phase 3 - pilot

Limited tender category, selected approved sources, officer usability testing, false-positive review, performance/load tests, audit review and controlled rollout.

Official research anchors used for this architecture

API Setu overview and SOP

API Setu describes a consumer-registration, subscription and provider-approval model. This supports an approved-source registry rather than unrestricted portal access.

<https://docs.apisetu.gov.in/document-central/explore-apisetu/Overview.html>

API Setu permitted access

API credentials must be used as assigned and access must use documented means. This supports scoped secrets, an egress gateway and no scraping.

<https://docs.apisetu.gov.in/document-central/terms-of-use/Permitted%20Access.html>

DigiLocker partner integration

Partner documentation describes formal onboarding and API configuration; EntityLocker materials describe OAuth authorization and a registered redirect URI. This supports consent or authority references and callback controls.

<https://www.digilocker.gov.in/web/partners/issuers>

Important: This plan does not claim production access to any provider. Each integration requires its own approved use case, agreement, credentials, scope and test path.